

ISO 27001:2022

Readiness Self-Assessment Report

Company: Groovy

Date: 01 June 2026

Overall Readiness: 51%

■ Moderate — Several gaps identified. Priority improvements recommended.

Executive Summary

The following table shows the readiness score for each of the 7 Annex A domains. Scores are calculated as the percentage of controls within each domain that are adequately addressed based on your responses.

Domain	Score	Status	Coverage
Organizational Controls	57%	■	4/7
People Controls	50%	■	2/4
Physical Controls	75%	■	3/4
Technological Controls	75%	■	6/8
Asset Management	0%	■	0/3
Cryptography	50%	■	1/2
Incident Management	50%	■	1/2

Overall Score: 51%

Gap Analysis by Domain

For each domain, controls that were not adequately addressed are listed below with their description and suggested next steps.

■ Organizational Controls — Score: 57% (4/7 covered)

A.5.8

Description: Information security risk assessment processes shall be defined, approved and applied.

Recommended Action: Establish a formal risk assessment process. Create a risk register and define risk treatment plans.

A.5.19

Description: Information security requirements for supplier relationships shall be defined and agreed.

Recommended Action: Define security requirements for supplier contracts. Conduct risk assessments for critical vendors.

A.5.20

Description: Suppliers shall be reviewed regularly for compliance with information security requirements.

Recommended Action: Establish a regular review process for supplier compliance with security requirements.

A.5.29

Description: Business continuity plans shall be developed and maintained to ensure continuity of information security.

Recommended Action: Develop a Business Continuity Plan that covers IT systems and data recovery.

A.5.30

Description: Business continuity plans shall be tested and reviewed regularly.

Recommended Action: Schedule regular testing of business continuity plans (at least annually). Document test results.

■ People Controls — Score: 50% (2/4 covered)

A.6.3

Description: All personnel shall receive appropriate information security awareness training and updates.

Recommended Action: Develop a security awareness training programme including induction and annual refresher courses.

A.6.5

Description: Access rights of personnel shall be removed upon termination of their employment or contract.

Recommended Action: Create an offboarding checklist that ensures all access is revoked within 24 hours of termination.

■ Physical Controls — Score: 75% (3/4 covered)

A.7.8

Description: Equipment shall be protected from environmental threats such as fire, flood, and power failures.

Recommended Action: Install environmental protections: fire suppression, UPS, climate control, and flood detection in equipment rooms.

■ Technological Controls — Score: 75% (6/8 covered)

A.8.2

Description: Access to information and systems shall be revoked or modified when no longer required.

Recommended Action: Implement a process to promptly revoke or modify access when personnel change roles or leave the organization.

A.8.3

Description: Access rights shall be reviewed at regular intervals.

Recommended Action: Conduct quarterly access rights reviews. Verify that user permissions align with current job requirements.

A.8.20

Description: Network security controls shall be implemented to protect services from unauthorized access.

Recommended Action: Implement network security controls including firewalls, network segmentation, and access control lists.

A.8.21

Description: Security mechanisms shall be applied to web applications to protect against web-based attacks.

Recommended Action: Deploy a Web Application Firewall (WAF) and implement security headers for web applications.

■ Asset Management — Score: 0% (0/3 covered)

A.5.9

Description: An inventory of information assets shall be maintained and kept current.

Recommended Action: Implement an asset management system (e.g., CMDB) to maintain a current inventory of all information assets.

A.5.12

Description: Information shall be classified according to its sensitivity and criticality.

Recommended Action: Implement an information classification scheme (labels: Confidential, Internal, Public). Train staff on handling each class.

A.5.11

Description: Assets shall be returned and media disposal shall be carried out securely.

Recommended Action: Create a secure disposal policy. Use certified data destruction services for media and devices.

A.7.14

Description: Equipment containing storage media shall be verified that sensitive data has been securely erased or destroyed.

Recommended Action: Implement secure media disposal procedures including secure erase, physical destruction, and certificate of destruction.

■ **Cryptography — Score: 50% (1/2 covered)**

A.8.24

Description: Cryptographic controls shall be used to protect the confidentiality of information on mobile devices.

Recommended Action: Enable full-disk encryption (e.g., BitLocker, FileVault) on all laptops and mobile devices.

■ **Incident Management — Score: 50% (1/2 covered)**

A.5.24

Description: Information security incident management processes shall be defined and applied.

Recommended Action: Develop and document an Incident Response Plan covering preparation, detection, containment, eradication, and recovery.

A.5.25

Description: Roles and responsibilities for incident response shall be assigned and documented.

Recommended Action: Assign incident response roles and ensure the team receives appropriate training.

Full Q&A; Transcript

The complete list of all 30 questions and the responses provided during the assessment.

Q1. [Q01] Do you have a documented Information Security Policy?

Answer: yesss we have policyyyy

Matched Controls: A.5.1

Q2. [Q02] Are roles and responsibilities for information security clearly defined?

Answer: yess in our company roles and resoonbilites deifneee

Matched Controls: A.5.2

Q3. [Q03] Do you have a process for managing information security risks?

Answer: no

Matched Controls: None

Q4. [Q04] Is there a process for handling supplier/third-party security?

Answer: no

Matched Controls: None

Q5. [Q05] Do you conduct internal information security audits?

Answer: yessss every week

Matched Controls: A.5.35

Q6. [Q06] Is there a business continuity plan that covers IT/data?

Answer: no

Matched Controls: None

Q7. [Q07] Do you have a legal/compliance register for data protection laws?

Answer: yessss we havea legel register for data protection

Matched Controls: A.5.31, A.5.34

Q8. [Q08] Do you conduct background checks on new employees?

Answer: yesss often check this beacuse some empolyeeee chance have to sell our company data to another company also revel our client

Matched Controls: A.6.1

Q9. [Q09] Is security training provided to all staff?

Answer: yesssas

Matched Controls: None

Q10. [Q10] Do employees sign confidentiality/NDA agreements?

Answer: yesss all have to sign

Matched Controls: A.6.2

Q11. [Q11] Is there a process for offboarding employees (revoking access)?

Answer: no

Matched Controls: None

Q12. [Q12] Are server rooms / data centres physically secured?

Answer: yessss we have serverrooms

Matched Controls: A.7.1, A.7.2

Q13. [Q13] Do you control visitor access to sensitive areas?

Answer: yessss have contorl on to visitor access to sensitive areas beacuse not every employeeee goes in data center and head office

Matched Controls: A.7.3

Q14. [Q14] Is equipment protected against environmental threats?

Answer: no

Matched Controls: None

Q15. [Q15] Do you have a clear desk and clear screen policy?

Answer: yess we have that

Matched Controls: A.7.7

Q16. [Q16] Do you use multi-factor authentication (MFA)?

Answer: yesss we havee also this

Matched Controls: A.8.5

Q17. [Q17] Are access rights reviewed and revoked when no longer needed?

Answer: no]

Matched Controls: None

Q18. [Q18] Are all systems patched and updated regularly?

Answer: yesss our all system are patches. and upasate regurlary

Matched Controls: A.8.8

Q19. [Q19] Do you have antivirus / endpoint protection on all devices?

Answer: yes beacuseee we work on lan so our data not internertalso we have apple product

Matched Controls: A.8.7

Q20. [Q20] Is network traffic monitored for threats?

Answer: yesss network traffic monitored beacusae therae is chace of ddos attack

Matched Controls: A.8.16

Q21. [Q21] Do you have a Web Application Firewall (WAF) or similar?

Answer: no

Matched Controls: None

Q22. [Q22] Is data backed up regularly and tested for restore?

Answer: yesss every weeeek sata reguraly upadataed andn tested

Matched Controls: A.8.13

Q23. [Q23] Do you conduct penetration tests or vulnerability scans?

Answer: yesss every month we call cyber student and also condutct bug bounty for this

Matched Controls: A.8.8, A.8.25

Q24. [Q24] Do you maintain an inventory of all information assets?

Answer: yess

Matched Controls: None

Q25. [Q25] Is information classified according to sensitivity?

Answer: noo

Matched Controls: None

Q26. [Q26] Do you have a policy for secure disposal of media/devices?

Answer: no

Matched Controls: None

Q27. [Q27] Are laptops and mobile devices encrypted?

Answer: nooo

Matched Controls: None

Q28. [Q28] Is sensitive data encrypted at rest and in transit?

Answer: yesss sensitive data encryptedd

Matched Controls: [A.8.24](#), [A.5.10](#)

Q29. [Q29] Do you have an incident response plan?

Answer: no

Matched Controls: None

Q30. [Q30] Are security incidents logged and reviewed after resolution?

Answer: yesss they might possible partially

Matched Controls: [A.5.27](#), [A.5.28](#)